



Incident handler's journal

Date: 09/03/2026	Entry: 1
Description	A Phishing email, containing a malicious attachment, was sent to various company employees. Some employees downloaded said attachment. The result was the deployment of a ransomware, which encrypted the organization's computer files. A ransom note was also left. The note stated that company files were encrypted and demanded money in exchange for the decryption key. The company chose to shut down their computer systems, and reached out to several organisations to report the incident and seek assistance.
Tool(s) used	Ransomware, Phishing.
The 5 W's	Capture the 5 W's of an incident. - Who caused the incident? Organised group of unethical hackers. - What happened? A Phishing email, containing malicious attachments, was sent to various company employees. Some employees downloaded said attachment. The result was the deployment of a ransomware, which encrypted the organization's computer files. A ransom note was also left. The note stated that company files were encrypted and demanded money in exchange for the decryption key. - When did the incident occur? A Tuesday Morning at 9:00am. - Where did the incident happen? At a small U.S. health care clinic that specialises in delivering primary-care service.

	Why did the incident happen? Firstly, because targeted employees downloaded the malicious attachment, and the downloaded malware deployed ransomware. Secondly, because an organised group of unethical hackers wanted to make money off of a ransomware attack.
Additional notes	Firstly, it is unclear how the ransomware group wants payment to be made. Secondly, it is unclear if the ransomware group has made their identity known. Thirdly, I have a question. If the group's identity is known, what is their track record of giving effective decryption keys after payment is made?

Date: 23/03/2026	Entry: 2
Description	A suspicious file was downloaded on an employee's computer. After investigating the email attachment file's hash, the attachment was verified as being malicious. The investigation is yet to be completed, and the alert currently is unresolved. The incident occurred in the Detection & Analysis stage of the NIST Incident Response Lifecycle. Reason being that said stage includes security team approaches that are done with the purpose of identifying the nature and impact of the attack.
Tool(s) used	VirusTotal. VirusTotal is an online investigative tool that analyses suspicious files, domains, IPs and URLs to detect malware and other breaches, as well as automatically shares them with the security community. In this incident, the security team

	used VirusTotal to analyse a file hash, to determine whether it was malicious.
The 5 W's	Capture the 5 W's of an incident. - Who caused the incident? Unknown threat actor(s). Possibly BlackTech. - What happened? Phishing attack. - When did the incident occur? Wednesday, July 20, 2022 09:30:14 AM - Where did the incident happen? Financial services company - Why did the incident happen? A phishing email, impersonating a third-party searching for hire and containing a malicious file, was sent to an employee's computer. The employee downloaded the file onto a company computer. The specific malware on the file was a malware known as Flagpro. Flagpro is used in the initial stage of an attack for network reconnaissance, to evaluate the target's environment, and to download and execute second-stage malware.
Additional notes	Alert Severity: - Medium Sender details - Sender email: 76tguyhh6tgftrt7tg.su, - Sender's email does not match sender's claimed name of 'Clyde West'. Mismatches between sender email addresses and sender's claimed name are a good indication that the email might be a phishing email Message body - Spelling/ Grammar mistakes: - Subject: Re: Infrastructure Egnieer role - Presumably attempted to write 'Engineer' but misspelled - Dear HR at Ingergy - Correct spelling is 'Inergyn', not Egnieer

	- I am writing for to express my interest in the engineer role posted from the website. - Correct grammar would be “I am writing to”, not “I am writing for to” - Spelling/ grammar errors can indicate a phishing attempt Attachments or links - File has been attached to this email. See: “Attachment: filename=“bfsvc.exe””
--	--

Date: 25/3	Entry: 3
Description	Recently, the company experienced a major security incident involving a data breach of over one million users. This contained Personally Identifiable information. Sidenote: There is an apparent conflict in reported information, as the final report states that only 50,000 customer records were affected. It's unclear how these two reported figures are mutually sound. End of sidenote. Further, the company's financial information was also part of the data breach. The financial impact of the incident is estimated to be \$100,000 in direct costs and potential loss of revenue. The incident is now closed and a thorough investigation has been conducted.
Tool(s) used	Forced browsing attack

The 5 W's	Capture the 5 W's of an incident. - Who caused the incident? Unknown individual. - What happened? Forced Browsing attack. - When did the incident occur? December 28, 2022, at 7:20 p.m., PT. - Where did the incident happen? Mid-sized retail company. - Why did the incident happen? Firstly, an unknown vulnerability existed in the organisation's e-commerce web application. Secondly, the attacker exploited said vulnerability to perform a forced browsing attack and access customer transaction data by modifying the order number included in the URL string of a purchase confirmation page. Thirdly, this vulnerability allowed the attacker to access customer purchase confirmation pages, exposing customer data, which the attacker then collected and exfiltrated. The motivations of the threat actor will now be explored. The motivation of the threat actor appears financial. This conclusion is drawn from the two emails that the presumed individual sent on December 22nd 2022, and December 28th 2022. Both emails included the ultimatum of either the company paying them a 5-figure dollar sum or the breached data would be leaked.
Additional notes	The security team made the following recommendations regarding how to prevent future recurrences. - Perform routine vulnerability scans and penetration testing. - Implement the following access control mechanisms:

	○ Implement allowlisting to allow access to a specified set of URLs and automatically block all requests outside of this URL range. ○ Ensure that only authenticated users are authorized access to content. A further recommendation could be to train employees to notify the security team whenever they are emailed in a way which shows a third-party bad actor claiming to have access to unauthorised company data.
--	--

Date: 02/04	Entry: 4
Description	The security team was tasked with monitoring traffic on the employer's network. To that end, they were tasked with configuring Suricata and using it to trigger alerts. Firstly, the team explored custom rules in Suricata. Secondly, they ran Suricata with a custom rule in order to trigger it and examined the output logs in the fast.log file. Finally, they examined the additional output the Suricata generated in the standard eve.json log file. This incident takes place across the Preparation phase of the NIST Incident Response Lifecycle. The reason being that part of the Preparation phase involves ensuring that an organization has the tools to respond to an incident and the appropriate security measures in place to stop an incident from happening in the first place. The security team's configuration of Suricata to monitor network traffic is a tool that can be used to stop an incident from happening in the first place. For example, by configuring Suricata to work as an

	IPS, malicious activity can be prevented on the network.
Tool(s) used	Suricata, Linux. The Suricata tool will now be explained. Suricata is an open-source software. It has three central functions. Firstly, as an Intrusion Detection System (IDS). In this capacity, Suricata monitors, and analyses network and/or host traffic, and produces alerts when a signature matches. Secondly, as an Intrusion Prevention System (IPS). In this capacity, Suricata acts like a firewall. It provides network filtering and monitoring, and allows network administrators to write and enforce detection rules. However, running Suricata in IPS mode requires additional configuration. Thirdly, as a Network Security Monitoring (NSM) tool. In this capacity, Suricata helps keep networks safe by producing and saving relevant logs. The software can analyse live network traffic, existing packet capture files, and create and save full or conditional packet captures.
The 5 W's	Capture the 5 W's of an incident. - Who caused the incident? Employer - What happened? The security team was tasked with monitoring traffic on the employer's network. They were required to configure Suricata, and to use it to trigger alerts. - When did the incident occur? Unknown - Where did the incident happen? Employer's network - Why did the incident happen?

	The employer presumably wanted a security team to ensure that only authorised persons had access to the employer's network, and saw tasking the security team with monitoring network traffic as being the/a solution for that.
Additional notes	Include any additional thoughts, questions, or findings.

Reflections/Notes:

Specific activities that were challenging for me and why

Journal entry 1 was particularly challenging for me. It was the first incident that I ever made an Incident handler journal entry about. So, I struggled with understanding what to write in the 'Why did this happen?', and in the 'additional notes section' of the first Incident Handler Journal. I also struggled with understanding how to draw the balance between being concise and also being comprehensively detailed enough.

How my understanding of incident detection and response changed has changed in this course

Yes. In many ways, my understanding of incident detection and response has changed. I now know about the four stages of the NIST Incident Response lifecycle, and the incident handler's journal, for example. A final example of a new learning is learning about the 'Post-incident activity' stage of the lifecycle. That entails events such as having a 'lessons learned' meeting. Prior to the course, incident detection and response seemed to refer just to the process of detecting, analysing and eradicating malicious activity on a network/ host.

The specific tool or concept that I enjoyed the most regarding detection and response, and why

My favourite concept was learning about the two common types of ways that IDSs, and similar tools, detect malicious activity on hosts, and/or networks. The two being signature, and anomaly analysis. The former pertains to developing rules for spotting known malicious attacks, such that IDS technologies will alert upon finding network activity with matching characteristics. The latter pertains to developing an understanding of the baseline activity on the network, and then making the IDS alert based on when there is a significant enough departure from baseline activity on the network. What I enjoyed so much about learning about this, is the creative strategy and trade-offs involved in the detection process. I got the sense that each approach to detection had its own strengths and weaknesses, and so the defence process was not a 'You must do this', but more of a 'There are multiple strong approaches to defence'. It reminds me of the video game 'Rainbow Six Siege', where the game is a complex tactical first-person shooter, where there are many high-level ways to protect a site from attackers. Each with their own strengths and weaknesses. Said video game is a passion of mine, and so the stated similarities helped expand my enjoyment of these detection concepts even further.

